МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РОССИЙСКОЙ ФЕДЕРАЦИИ
Федеральное государственное автономное образовательное учреждение высшего образования
«Дальневосточный федеральный университет»
(ДВФУ)

ИНСТИТУТ МАТЕМАТИКИ И КОМПЬЮТЕРНЫХ ТЕХНОЛОГИЙ (ШКОЛА)

Департамент математического и компьютерного моделирования

Лабораторная работа №1

по теме: «Анализ рисков информационной безопасности», вариант 8

Выполнил студент
гр. Б9123-02.03.01сцт
Ершова Валерия Константиновна

г. Владивосток
2026

Содержание

Задание 3

1 Обоснование выбора информационных активов организации 3

2 Оценка ценности информационных активов 4

3 Уязвимости системы защиты информации 5

4 Угрозы ИБ 6

5 Оценка рисков 7

6 Выводы 9

7 Литература 10

Задание

Для выполнения практической работы используется условное отделение полиции территориального органа МВД России. Формулировки задания приведены в соответствии с выданной методичкой.

№	Формулировка задания
1	Загрузите ГОСТ Р ИСО/МЭК ТО 27005-2010 «МЕТОДЫ И СРЕДСТВА ОБЕСПЕЧЕНИЯ БЕЗОПАСНОСТИ. Часть 3 «Методы менеджмента безопасности информационных технологий».
2	Ознакомьтесь с Приложениями C, D и E ГОСТа.
3	Выберите три различных информационных актива организации (см. вариант).
4	Из Приложения D ГОСТа подберите три конкретных уязвимости системы защиты указанных информационных активов.
5	Пользуясь Приложением C ГОСТа напишите три угрозы, реализация которых возможна пока в системе не устранены названные в пункте 4 уязвимости.
6	Пользуясь одним из методов предложенных в Приложении E ГОСТа произведите оценку рисков информационной безопасности.
7	Оценку ценности информационного актива производить на основании возможных потерь для организации в случае реализации угрозы.

1 Обоснование выбора информационных активов организации

В работе рассматривается условное отделение полиции территориального органа МВД России. Для оценки выбраны три различных информационных актива, которые обеспечивают регистрацию и обработку служебной информации, работу сотрудников и обмен данными внутри подразделения. Выбор сделан так, чтобы охватить разные стороны информационной среды: информационную базу, автоматизированное рабочее место и сетевую инфраструктуру.

№	Информационный актив	Назначение и обоснование выбора
1	Информационная база служебных материалов и обращений граждан	Содержит и обеспечивает обработку сведений, необходимых для регистрации обращений, ведения служебных материалов, поиска и подготовки информации. Потеря конфиденциальности или целостности может

№	Информационный актив	Назначение и обоснование выбора
		повлиять на служебные процессы и достоверность данных.
2	Автоматизированное рабочее место сотрудника дежурной части	Используется для ввода, просмотра и обработки информации в ходе повседневной работы. Ошибки при эксплуатации непосредственно влияют на корректность внесения данных и непрерывность работы сотрудника.
3	Локальная вычислительная сеть отделения полиции	Обеспечивает взаимодействие рабочих мест, серверов и сетевого оборудования. Ее состояние определяет возможность своевременного обмена служебной информацией и доступности сетевых сервисов.

Выбранные активы связаны между собой: информационная база используется через автоматизированные рабочие места, а доступ к ней и обмен данными обеспечиваются локальной сетью. Поэтому нарушение безопасности одного актива способно затронуть связанные с ним процессы и другие активы.

2 Оценка ценности информационных активов

В соответствии с заданием ценность информационного актива определяется по возможным потерям для организации в случае реализации соответствующей угрозы. В работе использованы условные оценки, так как фактическая статистика инцидентов конкретного подразделения и его финансовые показатели в исходных данных отсутствуют. Возможные потери включают затраты на восстановление, простой, расследование и устранение последствий, а также связанные с этим организационные и репутационные последствия.

Для последующего расчета по примеру 2 Приложения Е.2.2 используется пятиуровневая шкала ценности актива: 1 - минимальные последствия, 2 - низкие, 3 - средние, 4 - высокие, 5 - очень высокие. Денежная оценка ниже является обоснованием выбора уровня, а не утверждением о фактическом размере ущерба.

№	Информационный актив	Возможные потери при реализации угрозы	Ценность V (1-5)	Обоснование
1	Информационная база служебных материалов и обращений граждан	Около 3,0 млн руб. и более: восстановление данных, расследование инцидента, простой, повторная обработка информации, последствия нарушения конфиденциальности и целостности.	5	Очень высокое значение для служебных процессов и значительные последствия компрометации.
2	Автоматизированное рабочее место сотрудника дежурной части	Около 1,2 млн руб.: простой рабочего места, восстановление состояния и данных, потери рабочего времени и повторное выполнение операций.	4	Высокая важность для текущей работы, но воздействие локализуется на отдельном рабочем месте.
3	Локальная вычислительная сеть отделения полиции	Около 2,2 млн руб.: простой нескольких рабочих мест, восстановление сетевого взаимодействия, поиск причины и устранение последствий нарушения.	5	Высокое влияние на доступность сразу нескольких информационных систем и рабочих мест.

3 Уязвимости системы защиты информации

Уязвимости выбраны из Приложения D, таблицы D.1 «Примеры уязвимостей и угроз». Для каждого из трех активов выбрана одна конкретная уязвимость, которая непосредственно связана с рассматриваемой угрозой и позволяет построить сценарий инцидента.

№	Информационный актив	Вид	Конкретная уязвимость из Приложения D	Связанная примером угроза
1	Информационная база служебных материалов и обращений граждан	Программные средства	Неверное распределение прав доступа	Злоупотребление правами

№	Информационный актив	Вид	Конкретная уязвимость из Приложения D	Связанная примером угроза
2	Автоматизированное рабочее место сотрудника дежурной части	Персонал	Ненадлежащее использование программных и аппаратных средств	Ошибка в использовании
3	Локальная вычислительная сеть отделения полиции	Сеть	Ненадежная сетевая архитектура	Дистанционный шпионаж

Выбор уязвимостей соответствует логике ГОСТ: наличие уязвимости само по себе не создает ущерба; риск возникает при наличии угрозы, которая может воспользоваться данной уязвимостью. Поэтому в следующем разделе каждой уязвимости сопоставляется угроза из Приложения С.

4 Угрозы ИБ

Угрозы выбраны из Приложения С, таблицы С.1 «Примеры типичных угроз». В таблице указано происхождение угрозы: «У» - умышленная, «С» - случайная. Для каждого актива сформирован сценарий того, как угроза может реализоваться через выбранную уязвимость.

№	Уязвимость	Угроза ИБ из Приложения С	Происхождение	Сценарий возможного инцидента
1	Неверное распределение прав доступа	Злоупотребление правами	С, У	Пользователь, получивший избыточные права доступа к информационной базе, использует их за пределами служебной необходимости: получает доступ к сведениям, которые не требуются для выполнения его функций, либо совершает недопустимые действия с данными.
2	Ненадлежащее использование программных и аппаратных средств	Ошибка при использовании	С	Сотрудник допускает ошибку при эксплуатации автоматизированного рабочего места: неверно выполняет операцию, изменяет или удаляет

№	Уязвимость	Угроза ИБ из Приложения С	Происхождение	Сценарий возможного инцидента
				данные либо нарушает нормальный порядок работы, что приводит к потере времени и нарушению целостности или доступности информации.
3	Ненадежная сетевая архитектура	Дистанционный шпионаж	У	Внешний нарушитель использует слабости сетевой архитектуры для проведения дистанционного наблюдения за информационным обменом и получения сведений, которые должны оставаться защищенными.

Для оценки риска далее используются именно эти три сценария инцидентов. При определении последствий учитывается влияние на конфиденциальность, целостность и доступность информации и на нормальную деятельность подразделения.

5 Оценка рисков

Для оценки рисков выбран один из подходов Приложения Е ГОСТ - Е.2.2 «Пример 2 - Ранжирование угроз посредством мер риска». В этом подходе последствия (ценность актива) оцениваются по заранее определенной шкале, степень вероятности возникновения угрозы по шкале, например, от 1 до 5, после чего мера риска вычисляется умножением двух значений. В данной работе применена формула: $R = V \times P$, где V - ценность актива, P - степень вероятности реализации угрозы.

Шкала вероятности в отчете установлена для обеспечения повторяемости учебной оценки: 1 - очень низкая; 2 - низкая; 3 - средняя; 4 - высокая; 5 - очень высокая.

Значение P	Степень вероятности	Критерий для учебной оценки
1	Очень низкая	Реализация маловероятна, требуется редкое сочетание условий.
2	Низкая	Реализация возможна, но ожидается нечасто.
3	Средняя	Сценарий реалистичен и может реализоваться при обычном стечении обстоятельств.
4	Высокая	Сценарий вероятен при существующей уязвимости.
5	Очень высокая	Сценарий может возникать часто или при небольших усилиях нарушителя.

№	Актив	Уязвимость	Угроза	V	P	R=V×P	Ранг
1	Информационная база служебных материалов и обращений граждан	Неверное распределение прав доступа	Злоупотребление правами	5	4	20	1
2	Автоматизированное рабочее место сотрудника дежурной части	Ненадлежащее использование программных и аппаратных средств	Ошибка при использовании	4	3	12	3
3	Локальная вычислительная сеть отделения полиции	Ненадежная сетевая архитектура	Дистанционный шпионаж	5	3	15	2

По полученным значениям первое место по приоритету занимает риск, связанный с информационной базой: $R = 5 \times 4 = 20$. Второе место занимает риск дистанционного шпионажа через ненадежную сетевую архитектуру: $R = 5 \times 3 = 15$. Третье место занимает риск ошибки при использовании автоматизированного рабочего места: $R = 4 \times 3 = 12$.

Приоритет	Сценарий	R	Итоговая оценка
1	Злоупотребление правами при доступе к информационной базе	20	Очень высокий риск
2	Дистанционный шпионаж с использованием ненадежной сетевой архитектуры	15	Высокий риск
3	Ошибка при использовании автоматизированного рабочего места	12	Высокий риск

6 Выводы

В практической работе проанализированы три информационных актива условного отделения полиции территориального органа МВД России: информационная база служебных материалов и обращений граждан, автоматизированное рабочее место сотрудника дежурной части и локальная вычислительная сеть.

Ценность активов определена по возможным потерям для организации. Информационной базе и локальной сети присвоено значение 5, автоматизированному рабочему месту - 4.

Из Приложения D выбраны уязвимости: неверное распределение прав доступа, ненадлежащее использование программных и аппаратных средств и ненадежная сетевая архитектура. Им сопоставлены угрозы из Приложения C: злоупотребление правами, ошибка при использовании и дистанционный шпионаж.

По подходу E.2.2 Приложения E получены меры риска 20, 15 и 12. Наивысший приоритет имеет риск злоупотребления правами при работе с информационной базой; далее следуют дистанционный шпионаж и ошибка при использовании автоматизированного рабочего места.

Основными направлениями дальнейшей обработки риска являются корректное распределение прав доступа, повышение надежности сетевой архитектуры и безопасная эксплуатация автоматизированных рабочих мест.

7 Литература

1. Нормативная основа: ГОСТ Р ИСО/МЭК 27005-2010, Приложения C, D и E.